

FICHE DE RÉVISION - Gestion d'Intrusion

1. ORIGINE DE LA CYBERSÉCURITÉ

Les Premières Menaces (années 1970-1980)

1971 : Creeper - Premier programme auto-réplicatif

- Premier programme auto-réplicatif sur ARPANET
- Développé par **Bob Thomas** (BBN)
- Message affiché : *"I'm the creeper, catch me if you can!"*
- Fonctionnait sur ARPANET
- **Non malveillant** → expérimentation technique
- **Introduction du concept de propagation autonome sur réseau**

1988 : Morris Worm - Premier ver à grande échelle

- Créé par **Robert Tappan Morris**
- **≈ 6 000 machines infectées** (~10% d'Internet à l'époque)
- Exploitait :
 - Failles dans **sendmail**
 - Vulnérabilité **finger**
 - Faiblesses des mots de passe UNIX
- **Premier incident majeur de cybersécurité mondiale**
- **Introduction du concept de ver auto-propagatif à impact systémique**

1987 : Émergence des premiers antivirus

- Apparition des premiers outils de détection de virus
- Approche basée sur **signatures statiques**
- Protection principalement **locale** (pas encore réseau)

Facteurs Déclencheurs

Interconnexion croissante des systèmes informatiques

- Passage d'ARPANET à l'Internet académique
- Début de la connectivité internationale
- **Standardisation TCP/IP (1983)**

Militarisation des réseaux (ARPANET → Internet)

- ARPANET : Projet initial du **Département de la Défense US**
- Enjeu : **résilience en cas de conflit**
- Émergence des problématiques : **Confidentialité, Intégrité, Disponibilité (Triade CIA)**

Besoin de confidentialité des données sensibles

- Données militaires
- Données universitaires

- Premiers systèmes bancaires interconnectés
- Début des problématiques d'**espionnage numérique**

Premières Réponses Organisationnelles

1988 : Création du CERT

- **CERT** = Computer Emergency Response Team
- CERT Coordination Center, suite au Morris Worm
- **Naissance de la gestion structurée des incidents**

Développement des premiers pare-feu et mécanismes d'authentification

- **Apparition des premiers pare-feu :**
 - Filtrage par adresse IP et port
 - Contrôle des flux entrants/sortants
 - Début des architectures sécurisées périmétriques
 - **Passage d'une sécurité locale à une sécurité réseau**
- **Premiers mécanismes d'authentification :**
 - Amélioration des politiques de mots de passe
 - Introduction du **chiffrement asymétrique (RSA 1977)**
 - Début des systèmes d'identification centralisée

Évolution Chronologique de la Cybersécurité

Période	Approche	Caractéristiques
1970-1980	Premières menaces	Creeper (1971), Morris Worm (1988), Antivirus (1987)
Années 1990	Sécurité périmétrique	Modèle "château fort" : pare-feu et DMZ, protection réseau interne vs externe
Années 2000	Défense en profondeur	Multiplication des couches de sécurité, IDS/IPS, antivirus, segmentation réseau, détection d'anomalies
2010-2020	Approches modernes	Zero Trust ("Never trust, always verify"), Security by Design, Threat Intelligence, DevSecOps
Tendances actuelles	IA et Cloud	IA/ML pour détection des menaces, Sécurité cloud-native et conteneurisée, XDR (Extended Detection and Response)

2. CONCEPTS FONDAMENTAUX

Détection d'Intrusion

Définition La détection d'intrusion est le processus permettant d'identifier une activité **malveillante** ou **anormale** dans un système, un réseau ou une application.

Objectifs

- Détecter les attaques en cours
- Identifier les comportements suspects
- Repérer les violations de politique de sécurité
- **Réduire le temps de détection (MTTD)**

Pourquoi la détection est essentielle ? Dans une organisation moderne : - Les pare-feu ne suffisent plus - Les attaques contournent les défenses périmétriques - Les APT restent invisibles pendant des semaines - **La détection devient la 2ème ligne de défense**

Positionnement dans la chaîne d'attaque La détection intervient principalement durant : - Reconnaissance - Exploitation - Command & Control - Mouvement latéral - Exfiltration

Objectif stratégique Passer d'une posture : - **Réactive** (après compromission) - **Proactive** (détection précoce)

Types de Détection

Type	Description	Avantages/Limites
1. Détection par signature	Basée sur des règles connues	Rapide et efficace contre attaques connues, inefficace face aux zero-day . Ex: règle Snort détectant un scan Nmap
2. Détection comportementale (Anomalies)	Basée sur un modèle de comportement normal	Détecte écarts statistiques, adaptée aux APT
3. Détection basée IA / Machine Learning	Classification (RF, KNN, CNN, LSTM)	Détection de patterns complexes, sensible aux attaques adversariales

Types de Systèmes de Détection

Type	Fonction
NIDS	Analyse trafic réseau
HIDS	Surveillance hôte
IPS	Prévention inline
SIEM	Corrélation & vision globale

Cycle Opérationnel

Collecte → Analyse → Alerte → Investigation → Réponse

Réponse à Incident

Définition La réponse à incident (Incident Response) est l'ensemble des processus **organisationnels, techniques et juridiques** mis en œuvre pour : - Contenir un incident de sécurité - Limiter son impact - Restaurer les systèmes affectés - Préserver les preuves - Éviter la récurrence

Pourquoi la réponse est critique ? Même avec un IDS performant : - La détection ≠ protection totale - Le compromis peut déjà être actif - Le temps de réaction détermine l'impact - **Objectif : réduire le MTTR (Mean Time To Respond)**

Cadres de référence

- NIST SP 800-61
- Référentiel DGSSI Maroc
- ISO/IEC 27035

Position dans le cycle cyber Détection → Réponse → Éradication → Restauration → REX

Cycle Standard (modèle NIST adapté)

Phase	Actions
1. Préparation	Politique IR, Playbooks, SOC opérationnel, Équipe CERT interne
2. Détection & Analyse	Qualification alerte, Triage L1/L2, Analyse forensic, Mapping MITRE ATT&CK
3. Confinement (Containment)	Isolation machine, Blocage IP/C2, Segmentation réseau, Suspension comptes compromis
4. Éradication	Suppression malware, Patch vulnérabilités, Rotation mots de passe, Nettoyage persistance
5. Récupération	Restauration backups, Vérification intégrité, Surveillance renforcée
6. Retour d'expérience (REX)	Analyse causes racines, Mise à jour règles IDS, Amélioration playbooks, Sensibilisation utilisateurs

Rôles SOC Impliqués

- **Analyste L1** : triage
- **Analyste L2/L3** : investigation
- **Incident Manager**
- **Équipe Forensic**
- **RSSI / Direction**

Gestion des Vulnérabilités

Définition La gestion des vulnérabilités est un processus continu visant à : **Identifier, Évaluer, Prioriser, Corriger, Surveiller** les faiblesses techniques exploitables dans un système d'information.

Qu'est-ce qu'une vulnérabilité ? Une vulnérabilité est une **faiblesse exploitable par une menace** pour compromettre la confidentialité, l'intégrité ou la disponibilité.

Pourquoi c'est stratégique ?

- **80-90%** des intrusions exploitent des vulnérabilités connues
- La plupart des attaques réussies = **patch manquant**
- Réduit la surface d'attaque
- **La gestion des vulnérabilités est une mesure préventive majeure**

Vulnérabilité ≠ Menace ≠ Exploit

Élément	Description
Vulnérabilité	Faiblesse technique
Exploit	Code ou méthode d'exploitation
Menace	Acteur ou événement malveillant

Processus Continu (Vulnerability Management Lifecycle)

Étape	Actions
1. Découverte des actifs	Inventaire IT/OT, Shadow IT, Cartographie réseau
2. Scan des vulnérabilités	Outils (Nessus, OpenVAS, Qualys), Analyse CVE, Scan authentifié/non-authentifié
3. Évaluation & Priorisation	Score CVSS, Criticité métier, Exposition Internet, Présence d'exploit public → Risk-Based Vulnerability Management
4. Remédiation	Patch management, Reconfiguration, Désactivation service, Segmentation réseau
5. Vérification & Reporting	Re-scan, KPI : Temps moyen de correction (MTTR vuln), % vuln critiques ouvertes, Taux de conformité patch

Alignement Normatif

- **ISO 27001 – A.12.6.1**
- **NIST CSF** (Identify & Protect)
- **DGSSI Maroc** – Gestion des risques SI

Message Clé

La gestion des vulnérabilités est le pont entre prévention et détection. Elle réduit le nombre d'alertes SOC et diminue la probabilité d'incident majeur.

- **Sans gestion des vulnérabilités** : Reconnaissance → Exploitation → Intrusion
- **Avec gestion efficace** : Reconnaissance → Échec exploitation

Sécurité Défensive vs Sécurité Offensive

Sécurité Défensive (Blue Team) Ensemble des stratégies visant à : - Protéger les systèmes - Détecter les intrusions - Répondre aux incidents - Maintenir la résilience

Exemples : IDS/IPS, SIEM, SOC, EDR, Gestion des vulnérabilités, Incident Response

Objectif : Réduire l'impact d'une attaque

Sécurité Offensive (Red Team) Ensemble des techniques simulant un attaquant réel pour : - Identifier les failles - Tester la robustesse des défenses - Exploiter vulnérabilités - Évaluer posture sécurité

Exemples : Pentest, Exploitation, Phishing simulé, Red Team engagement, Social engineering

Objectif : Découvrir les faiblesses avant l'attaquant réel

Comparaison Synthétique

Critère	Défensive	Offensive
Approche	Réactive & proactive	Simulative & agressive
Objectif	Protection & détection	Exploitation contrôlée
Outils	SIEM, IDS, EDR	Metasploit, Nmap, Cobalt Strike
Indicateur clé	MTTD / MTTR	Taux de compromission

Purple Team

Collaboration structurée entre : - Offensive - Défensive - Threat Intelligence

Objectif : Améliorer la posture sécurité globale

Cycle d'amélioration continue

1. Red Team attaque
2. Blue Team détecte
3. Analyse des écarts
4. Amélioration des règles IDS
5. Renforcement architecture → **Cela donne naissance à la Purple Team**

Message Stratégique

La cybersécurité moderne ne choisit pas entre offensive ou défensive. Elle intègre les deux dans une stratégie unifiée de résilience.

Cyber Sécurité & Sûreté de Fonctionnement

Sûreté de Fonctionnement (Dependability) - Attributs FMCD

- **Fiabilité** : continuité du service
- **Maintenabilité** : capacité de réparation
- **Confidentialité** : absence de divulgation non autorisée

- **Disponibilité** : accessibilité du service
- **Intégrité** : absence d'altération inappropriée

Convergence Sécurité-Sûreté

- Les cyberattaques menacent la disponibilité (DoS/DDoS)
- L'intégrité compromise = défaillances système
- **Nécessité d'une approche holistique**

Triade CIA en Cybersécurité

- **Confidentiality** (Confidentialité)
- **Integrity** (Intégrité)
- **Availability** (Disponibilité)

Menaces vs Défaillances

- Menaces **intentionnelles** (attaques) vs **accidentelles** (pannes)
- Besoin de mécanismes de tolérance aux fautes ET aux intrusions

Statistiques 2023-2024 : Pourquoi la Sécurité Réseau ?

Statistique	Valeur
Entreprises ayant subi au moins 1 cyberattaque	93%
Coût moyen d'une violation de données	4,45 M\$ USD
Temps moyen de détection d'une intrusion	277 jours
Cyberattaques ciblant les PME	43%

"Il ne s'agit pas de savoir SI vous serez attaqué, mais QUAND vous le serez."

3. CLASSIFICATION DES ATTAQUES

Cyber Kill Chain (Lockheed Martin, 2011)

Les 7 Phases d'une Intrusion

Phase	Description	Catégorie
1. Reconnaissance	Scanning, harvesting d'informations (social media)	Intrusion
2. Weaponization (Armement)	Pairing malicious code with exploit	Intrusion
3. Delivery (Livraison)	Transmission via email, USB, website	Intrusion
4. Exploitation	Déclenchement du code malveillant	Incident
5. Installation	Installation du malware sur le système	Incident

Phase	Description	Catégorie
6. Command & Control (C2)	Canal de commande pour manipulation à distance	Compromission
7. Actions on Objectives	Atteinte des objectifs (exfiltration, sabotage)	Compromission

Intrusion (Tentative)

Définition Tentative d'accès non autorisé à un système, réseau ou données.

Caractéristiques

- Peut être bloquée **AVANT** le succès
- Détectable par les systèmes de sécurité
- N'implique pas nécessairement un impact

Exemples

- Scan de ports
- Brute force SSH
- Injection SQL bloquée

Incident (Impact CIA)

Définition Événement qui compromet la **CIA** (Confidentialité, Intégrité, Disponibilité).

Triangle CIA - Exemples d'impact

Pilier	Exemple d'attaque
Confidentialité	Vol de données clients
Intégrité	Défacement de site web
Disponibilité	Attaque DDoS (Distributed Denial of Service)

Compromission (Contrôle Effectif)

Définition Prise de contrôle **EFFECTIVE** d'un système par un attaquant.

Caractéristiques

- Persistance de l'attaquant dans le système
- Accès privilégié obtenu
- Capacité d'action sur le système

Exemples

- Backdoor actif
 - Compte admin créé
 - C2 établi
-

Comparaison : Intrusion → Incident → Compromission

Progression de la gravité

Niveau	Description
Intrusion	Tentative (peut être bloquée)
Incident	Succès avec impact
Compromission	Contrôle total et persistance

NIST Incident Response Cycle

- **Preparation** → **Intrusion** (Detection & Analysis) → **Incident** (Containment, Eradication, & Discovery) → **Compromission** (Post-Incident Activity)
-

APT : Advanced Persistent Threat

Définition Attaque **sophistiquée, ciblée et prolongée** menée par des acteurs étatiques.

Caractéristiques (A-P-T)

- **ADVANCED** : Techniques sophistiquées, zero-day
- **PERSISTENT** : Présence longue durée (mois/années)
- **THREAT** : Objectifs stratégiques (espionnage, sabotage)

Caractéristiques détaillées

- Attaque sophistiquée, ciblée, prolongée
- Acteurs étatiques
- Zero-day exploits
- Présence longue durée (mois/années)
- Objectifs stratégiques

Exemples célèbres

- **APT28** (Russie)
 - **APT29** (Russie)
 - **Lazarus Group** (Corée du Nord)
-

TP1 : Détection d'un Scan Nmap

Objectif

Appliquer la détection d'une phase de reconnaissance et comprendre la réponse IDS/IPS.

Environnement

- Kali Linux (attaquant)
- Ubuntu 22.04 + Snort IDS
- Réseau lab : 192.168.100.0/24
- Wireshark pour capture

Manipulation

```
$ nmap -sS -sV 192.168.100.10  
$ nmap -sT 192.168.100.10  
$ nmap -A 192.168.100.10
```

Questions à résoudre

1. Quelle différence entre SYN scan (-sS) et TCP connect (-sT) ?
2. Que voit précisément un IDS lors d'un scan SYN ?
3. À quel moment un IPS peut-il bloquer le scan ?
4. Analyser les logs Snort : combien d'alertes générées ?

Exemple d'alerte IDS

```
IDS ALERT  
Port Scan Detected  
Source: 41.x.x.x  
Target: 196.200.x.x  
Ports: 22,80,443,3306  
Signature: NMAP SYN  
Severity: MEDIUM  
Action: Log + Notify
```

Livrable attendu

Rapport analyse : capture Wireshark + logs IDS + réponses argumentées

POINTS CLÉS À RETENIR

Chronologie

- **1971** : Creeper (premier programme auto-répliatif)
- **1987** : Premiers antivirus
- **1988** : Morris Worm + Création du CERT
- **1977** : RSA (chiffrement asymétrique)
- **1983** : Standardisation TCP/IP

Triade CIA

- **Confidentialité** : Protection accès non autorisés
- **Intégrité** : Garantie données non modifiées
- **Disponibilité** : Accessibilité ressources

Types de détection

1. **Par signature** : règles connues, inefficace zero-day
2. **Comportementale** : anomalies, adaptée APT
3. **IA/ML** : patterns complexes, sensible attaques adversariales

Systèmes de détection

- **NIDS** : Network IDS
- **HIDS** : Host IDS
- **IPS** : Intrusion Prevention System
- **SIEM** : Security Information and Event Management

Cycle de réponse NIST

1. Préparation
2. Détection & Analyse
3. Confinement
4. Éradication
5. Récupération
6. REX (Retour d'expérience)

Kill Chain (7 phases)

1. Reconnaissance
2. Weaponization
3. Delivery
4. Exploitation
5. Installation
6. Command & Control
7. Actions on Objectives

Métriques clés

- **MTTD** : Mean Time To Detect
- **MTTR** : Mean Time To Respond

Teams

- **Blue Team** : Défensive (protection, détection)
- **Red Team** : Offensive (pentest, exploitation)
- **Purple Team** : Collaboration Blue + Red